

Changelog Addendum - 2026-02-23

Summary

This addendum records the latest hardening and consistency updates completed on February 23, 2026 for Doctor, Nurse, Pharmacy, Reception, and IT dashboards.

Implemented Improvements

1) Nurse timeline SQL injection hardening

- File: backend/routes/nurse.php
- Endpoint: GET /nurse/timeline
- Changes:
 - Removed direct SQL interpolation of patient_id.
 - Replaced with prepared statements for all timeline queries.
 - Added safe-query fallbacks and guarded error handling.
- Why: Prevent injection risk and avoid raw 500 failures.

2) IT dashboard duplicate bootstrapping cleanup

- File: frontend/pages/it/itdashboard.html
- Changes:
 - Removed duplicate app.js include.
 - Removed duplicate protectPage(['it_support', 'admin']) call.
- Why: Avoid duplicated initialization, duplicate API calls, and inconsistent UI state.

3) Cross-module status normalization

- Files:
 - backend/routes/doctor.php
 - backend/routes/nurse.php
 - backend/routes/pharmacy.php
 - backend/routes/reception.php
- Changes:
 - Updated mixed-case status checks to consistent LOWER(status) comparisons.
 - Normalized pending/dispensed/waiting/urgent filters used by dashboard metrics and lists.
- Why: Prevent data misses caused by inconsistent status casing and wording.

4) Appointment ownership rules (Doctor + Reception flow)

- File: backend/routes/doctor.php
- Changes:

- Added scoped listing support in GET /doctor/appointments (scope=mine_or_unassigned).
- POST /doctor/appointment_update now:
 - allows claim-and-update for unassigned appointments,
 - returns 403 if appointment is not owned/claimable.
- Added is_unassigned in appointment list payload.
 - Why: Make ownership behavior explicit and prevent silent cross-user appointment updates.

5) Doctor sidebar tab handler modernization

- File: frontend/pages/doctor/dashboard.html
- Changes:
 - Replaced inline onclick="switchTab(...)" tab links with data-tab links.
 - Added event listener binding (bindDoctorNavTabs) for tab navigation.
 - Kept hash-based deep linking support.
- Why: Reduce brittle inline JS coupling and prevent undefined-handler runtime issues.

Additional Frontend Wiring

- File: frontend/pages/doctor/dashboard.html
- Change:
 - Appointment loading now calls /doctor/appointments?scope=mine_or_unassigned.
 - Unassigned appointment action label now shows Claim & Start.

Validation Performed

- php -l backend/routes/nurse.php -> no syntax errors.
- php -l backend/routes/doctor.php -> no syntax errors.
- php -l backend/routes/pharmacy.php -> no syntax errors.
- php -l backend/routes/reception.php -> no syntax errors.
- Verified IT page has a single app.js include and single protectPage(...) call.
- Verified Doctor page no longer uses inline onclick="switchTab(...)" for sidebar tabs.

Changed Files

- backend/routes/doctor.php
- backend/routes/nurse.php
- backend/routes/pharmacy.php
- backend/routes/reception.php
- frontend/pages/doctor/dashboard.html
- frontend/pages/it/itdashboard.html